Abhinnati — Admin Dashboard Architecture Plan

System Architecture, Security Specification & Implementation Roadmap

Target Platform: Next.js 16 (App Router), Prisma 6, Supabase PostgreSQL	**Date:** October 2026
Scope: Internal Operations Desk (Vendor KYC, Users, Categories, Feed)	**Status:** Ready for Implementation

1. Executive Summary & Current State Analysis

Current State: The backend is running on localhost:3000 and is **100% connected** to the live Supabase PostgreSQL database via Prisma ORM. Live counters on the KYC screen (e.g., *Approved Vendors: 1*, *Total: 1*) are directly fetched from Supabase.

Why other sidebar buttons cannot be clicked: The initial developer wrote the complete database query for the *KYC Approvals* view, but only created static HTML placeholder elements for the remaining 4 sidebar buttons (*User Management, Content Moderation, Analytics, Settings*). There are no click handlers, tab states, or subpages attached to them.

Security Vulnerability: The admin dashboard currently lacks an authentication gate. Any visitor navigating to /admin can view the interface. An admin login system must be implemented immediately.

Feature / View	Current State	Target Architecture State
Admin Authentication	■ None (Publicly exposed)	Secure Login Gate (/admin/login) with bcrypt, JWT, and httpOnly cookie session guard.
KYC Approvals Desk	■ Partial (List & Approve only)	Aadhaar/License inspection modal, verified badges, and 'Reject with mandatory reason' flow.
User Management	■ Unclickable placeholder	Live searchable table of all residents, vendors, and admins with status toggle (Active/Suspended).
Category Management	■ Missing from dashboard	Bilingual taxonomy desk (Marathi & English names, icon mapping, active switch, order).
Content Moderation	■ Unclickable placeholder	Local feed inspector: filter community posts by area, remove spam or inappropriate issues.

2. System Architecture & Security Specification

The admin desk is an internal web operations interface designed exclusively for the Abhinnati staff. As detailed in the Knowledge Transfer documentation, it operates as an internal review console, entirely separate from the resident mobile app.

A. Admin Authentication & Session Security

1. Default Seeded Credentials:
• Phone: 9999999999
• Email: admin@abhinnati.com
• Password: Admin@123 (Stored as a one-way bcrypt salted hash in Supabase)
• System Role: admin

2. Login Workflow (/admin/login):
• Admin inputs phone or email and password.
• Request is processed by POST /api/v1/admin/auth/login.
• The system validates the bcrypt hash and explicitly checks: user.role === 'admin'. Non-admin users are rejected with 403 Forbidden.
• Upon success, the server issues a signed JWT containing { userId, role, phone } inside an **httpOnly, SameSite=Lax, Secure cookie** named abhinnati_admin_session.
• The cookie cannot be stolen via JavaScript XSS attacks.

3. Route Guard & Middleware Protection:
• Next.js layout guard inspects every inbound request to /admin/*.
• If the cookie is absent or invalid, the user is redirected to /admin/login.
• The navigation bar includes the logged-in admin's profile and a 1-click **Logout** button that destroys the cookie session.

B. Database & Prisma Data Flow

All data actions flow directly through Prisma Client into Supabase:

Layer	Component	Responsibility
Presentation	Next.js App Router (React)	Admin client dashboard, interactive tabs, modals, tables, and login screen.
API / Server	Route Handlers (/api/v1/admin/*)	Validates admin JWT session, processes approvals, updates users, handles categories.
ORM Layer	Prisma Client (v6.19.3)	Type-safe database abstraction using transaction and session poolers.
Persistence	Supabase PostgreSQL	Stores User, Vendor, Business, Category, Booking, Notification, and Audit tables.

3. Detailed Module Specifications (Aligned with Knowledge Transfer)

Module 1: Vendor KYC Verification Desk (Pages 5 & 9)

Requirement: When a resident registers a business on the mobile app, they submit identity proof (mandatory Aadhaar card, optional FSSAI licence for food businesses, GST, shop licence). The profile remains *'Under review'* until approved by Admin.

Admin Actions:

• **Inspection Modal:** Clicking any pending vendor opens their profile showing business name (Marathi + English), category, phone, operating radius, and clickable document links (Aadhaar, FSSAI).

• **Approve:** Updates kycStatus = 'approved'. Unlocks Vendor Mode on the mobile phone and sends an approval notification.

• **Reject with Reason:** Prompts the admin to enter a rejection explanation (e.g. *'Aadhaar image is unclear, please upload a sharper photo'*). Updates status to 'rejected' and records the reason so the vendor can see it and resubmit.

Module 2: User & Vendor Management Desk

Requirement: The admin team needs complete oversight of all residents, vendors, and platform users.

Admin Capabilities:

• Search users by phone number or name.

• Filter list by role (All, Residents, Vendors, Admins).

• Inspect registration date, language preference (Marathi / English), and total orders/bookings.

• Suspend or deactivate rogue or fraudulent accounts.

Module 3: Bilingual Category Governance (Pages 3 & 9)

Requirement: The Explore screen in the mobile app displays local service categories (Bakery, Cleaning, Plumbing, Electrical, Tiffin, Legal). Admin must govern these taxonomies.

Admin Capabilities:

• View all categories stored in the Category table.

• Edit Marathi names (e.g. Marathi translations of Bakery, Sweets) and English names.

• Assign Lucide icon identifiers (e.g. Utensils, Scissors, Wrench).

• Toggle category visibility (Active / Inactive) without deleting historical data.

• Adjust display order to highlight seasonal or popular services.

Module 4: Community Content Moderation Desk (Page 5)

Requirement: Abhinnati provides a neighbourhood feed for local issues and community questions. The operations desk must maintain safety and trust.

Admin Capabilities:

• Filter community feed posts by neighbourhood circle (Bandra West, Kothrud, etc.).

• View flagged or reported issues.

• 1-Click delete/remove inappropriate posts or comments from the live feed.

Module 5: System Analytics & Overview

Metrics Tracked: Total Users, Approved Vendors, Pending Reviews, Total Completed Bookings, and distribution across operational circles (Mumbai, Pune, Nashik).

4. Step-by-Step Implementation Roadmap

Phase	Deliverables	Outcome
Phase 1: Authentication & Security Gate	1. Create /admin/login page. 2. Implement POST /api/v1/admin/auth/login. 3. Protect /admin/* routes with httpOnly cookie guard. 4. Add Logout button to dashboard header.	The admin portal is locked down. Only authorized staff with password can access the panel.
Phase 2: Interactive Tabs & KYC Workflow	1. Update AdminDashboardClient.tsx with dynamic activeTab state. 2. Make all sidebar buttons clickable. 3. Build KYC document inspection modal. 4. Build 'Reject with Reason' API and UI dialog.	Full vendor lifecycle management: Admin can view documents and approve or reject with feedback.
Phase 3: Live User Management Desk	1. Connect User Management tab to Supabase prisma.user query. 2. Add real-time search and role filter pills. 3. Account status toggle (Active/Suspended).	Complete visibility into residents, vendors, and their account histories.
Phase 4: Category & Content Desks	1. Build Category Manager view (Bilingual edit & active toggle). 2. Build Community Feed Moderation view (inspect and purge flagged posts).	100% feature-complete admin portal matching the Abhinnati Knowledge Transfer PDF.